

README — Kit GQM-PRAGMATIC v2025.1

Trazabilidad GQM + Calidad PRAGMATIC para Indicadores COSO-Ciber

Aplicación a España • ENS / NIS2 / DORA • Perspectiva Comparada Internacional

KIT GQM-PRAGMATIC • v2025.1 • ABRIL 2026
Marco integrativo de trazabilidad y calidad para métricas COSO-Ciber

¿Qué es este Kit y por qué existe?

El **Kit GQM-PRAGMATIC** es la extensión metodológica del Kit COSO-Ciber (v2025.1 — anterior), diseñada para responder a la pregunta que toda organización responsable debería hacerse antes de construir su cuadro de mando de ciberseguridad:

¿Cómo sabemos que las métricas que estamos midiendo son las correctas, y no simplemente las más fáciles de medir?

La respuesta combina dos metodologías complementarias:

- **GQM (Goal-Question-Metric)**: Garantiza que cada métrica existe porque responde a una pregunta relevante, que a su vez existe porque contribuye a un objetivo real — desde la Estrategia Nacional de Ciberseguridad hasta el dato técnico del SIEM.
- **PRAGMATIC (Brotby & Hinson, 2013)**: Evalúa la calidad de cada métrica bajo 9 criterios, eliminando las métricas vanidad y certificando que las que permanecen en el cuadro de mando merecen estar ahí.

Inventario del Kit (7 documentos)

#	Archivo	Descripción	Páginas	Audiencia
a	a_marco_gqm_pragmatic.md	Marco integrativo GQM+PRAGMATIC: ON → OO → Preguntas → 50 Métricas	~35	CISO / Metodólogos
b	b_matriz_pragmatic_completa.md	Evaluación de las 50 métricas bajo los 9 criterios PRAGMATIC + fichas detalladas	~28	CISO / Auditores
c	c_narrativa_explicativa_gqm.md	Por qué GQM+PRAGMATIC transforma la medición del ciberriesgo	~18	Consejo / C-level
d	d_mapeo_normativo_gqm.md	Trazabilidad de las 50 métricas a NIS2, DORA, ENS, COSO, ISO27001, NIST CSF, FAIR, AIAC, GDPR	~20	Compliance / Auditores
e	e_plantilla_excel_gqm_igm_rosi.md	Especificación de la plantilla Excel con árbol GQM, PRAGMATIC, IGM y ROSI	~30	CFO / GRC Analysts
f	f_plantilla_ppt_gqm_pragmatic.md	18 diapositivas especificadas para el Consejo con lógica GQM+PRAGMATIC	~40	CISO / Consultores
g	g_readme_kit_gqm.md	Este documento — guía de uso del kit	~15	Todos

El Catálogo de 50 Métricas

Las 50 métricas están organizadas en 10 familias, cada una vinculada a un Objetivo Organizacional (OO) derivado de los Objetivos Nacionales:

Familia	OO	# Métricas	Componente COSO	IATs
M-GOB (Gobernanza)	OO-1	5	C-I	4 ⚡
M-EST (Estrategia)	OO-2	5	C-II	1 ⚡
M-DET (Detección)	OO-3	5	C-III	2 ⚡
M-VUL (Vulnerabilidades)	OO-4	5	C-III	2 ⚡
M-IAM (Identidad)	OO-5	5	C-III	2 ⚡
M-SCM (Supply Chain)	OO-6	5	C-III	1 ⚡
M-RES (Resiliencia)	OO-7	5	C-III	3 ⚡
M-EMG (Emergentes)	OO-8	5	C-II+C-III	1 ⚡
M-RPT (Reporte)	OO-9	5	C-V	2 ⚡
M-ROI (ROI/ROSI)	OO-10	5	C-II	1 ⚡
TOTAL		50		19 ⚡

El Modelo de Calidad PRAGMATIC en Cifras

Resultados de la evaluación del catálogo completo:

PUNTUACIONES PRAGMATIC DEL CATÁLOGO GQM-CIBER v2025.1

Métricas Premium (36-45): 34 de 50 (68%) 
Métricas Aceptables(27-35): 16 de 50 (32%) 
Métricas Condicionales(<27): 0 de 50 (0%) 

Puntuación media: 37.8 / 45
Criterio más fuerte: Relevante (R = 4.9/5)
Criterio más débil: Independiente (I = 3.5/5)

Interpretación: El catálogo pasa el umbral PRAGMATIC de calidad en su totalidad. El único criterio con potencial de mejora sistemática es la Independencia — inherente al conflicto estructural de quien mide los propios controles.

Relación con el Kit COSO-Ciber v2025.1

Este kit es la **extensión metodológica** del Kit COSO-Ciber v2025.1. Los dos kits son complementarios:

Dimensión	Kit COSO-Ciber v2025.1	Kit GQM-PRAGMATIC v2025.1
Propósito	Instrumento de campo (encuesta)	Marco metodológico y de calidad
Pregunta central	¿Qué mide su organización?	¿Por qué debería medirlo, y cómo saber si vale la pena?
Artefacto principal	Encuesta de 59 preguntas	Catálogo de 50 métricas con árbol GQM
Filtro de calidad	IGM ponderado por componente COSO	IGM + PRAGMATIC + trazabilidad ON-OO-Q-M
Audiencia encuesta	CISOs, directivos, responsables	CISO, CFO, Consejo, auditor, investigador
Documentos	7 (a-g)	7 (a-g, este kit)
Uso recomendado	Diagnóstico organizacional	Diseño del sistema de medición

Flujo de uso integrado:

1. Usar Kit GQM-PRAGMATIC para DISEÑAR el sistema de métricas (qué medir, por qué, con qué calidad)
↓
2. Usar Kit COSO-Ciber para EVALUAR el estado actual (encuesta a los responsables, cálculo del IGM)
↓
3. Usar Plantilla Excel (Documento e de ambos kits) para CUANTIFICAR el riesgo y calcular el ROSI
↓
4. Usar Plantilla PPT (Documento f de ambos kits) para COMUNICAR al Consejo con el lenguaje adecuado

Instalación y Uso

Prerrequisitos

- Conocimiento del marco COSO ERM 2017 (recomendado: lectura del Documento c antes de comenzar)
- Para la plantilla Excel: Microsoft Excel 365 o Google Sheets
- Para implementar el sistema de métricas: acceso a las fuentes de datos listadas en el Documento a (SIEM, IAM/PAM platform, scanner de vulnerabilidades, CMDB)

Pasos de Implementación del Sistema de Métricas

FASE 1: ADOPCIÓN (Semanas 1-4)

- Leer el Marco GQM (Documento a) con el equipo de ciberseguridad
- Validar la relevancia de los 10 00 para la organización
- Identificar los 00 no aplicables (p.ej.: DORA si no es sector financiero)
- Aprobación del catálogo de métricas por el Comité de Ciberseguridad

FASE 2: EVALUACIÓN INICIAL (Semanas 5-8)

- Ejecutar la encuesta COSO-Ciber (Kit anterior) para diagnóstico base
- Recopilar valores actuales de las 50 métricas en la Plantilla Excel
- Calcular el IGM y ROSI iniciales
- Identificar los IATs en estado crítico (semáforo rojo)

FASE 3: PRESENTACIÓN AL CONSEJO (Semana 10)

- Preparar la presentación con la Plantilla PPT (Documento f)
- Solicitar las 4 decisiones descritas en la diapositiva 15
- Obtener aprobación del roadmap de mejora

FASE 4: OPERACIONALIZACIÓN (Semanas 11-24)

- Automatizar la recogida de datos de las métricas prioritarias (IATs)
- Implementar el dashboard en la plataforma GRC corporativa
- Establecer el ciclo de revisión trimestral al Consejo
- Programar la auditoría independiente de métricas con riesgo de sesgo

FASE 5: MEJORA CONTINUA (12 meses y sucesivos)

- Repetir la encuesta COSO-Ciber anualmente
- Revisar el catálogo de métricas ante cambios regulatorios
- Actualizar las puntuaciones PRAGMATIC si cambia el contexto

Marco Normativo de Referencia

Marco	Métricas con cobertura	Aplicabilidad en España
NIS2 (2022/2555)	50/50 (100%)	Entidades esenciales e importantes
COSO ERM 2017	50/50 (100%)	Universal
ISO/IEC 27001:2022	48/50 (96%)	Universal
NIST CSF 2.0	48/50 (96%)	Universal
ENS (RD 311/2022)	44/50 (88%)	Sector público y proveedores AAPP
DORA (2022/2554)	38/50 (76%)	Sector financiero supervisado
FAIR (OpenFAIR 2023)	14/50 (28%)	Cuantificación financiera del riesgo
EU AI Act (2024/1689)	6/50 (12%)	Sistemas IA de alto riesgo (desde agosto 2026)
GDPR (2016/679)	8/50 (16%)	Universal

Preguntas Frecuentes

P: ¿Este kit reemplaza al Kit COSO-Ciber v2025.1?

R: No. Son complementarios. El Kit COSO-Ciber es el instrumento de campo (encuesta); este kit es el fundamento metodológico. Se recomienda usar ambos.

P: ¿Es necesario implementar las 50 métricas desde el inicio?

R: No. La recomendación es empezar con los 19 IATs (Indicadores de Alerta Temprana) y las métricas Premium (PRAGMATIC ≥ 36) de mayor densidad regulatoria. El conjunto completo es el objetivo a 24 meses.

P: ¿Las puntuaciones PRAGMATIC son definitivas?

R: Son la evaluación del consorcio de expertos basada en el análisis del contexto. Pueden y deben ser revisadas en función de la realidad específica de cada organización (sus herramientas, su sector, su madurez en datos). El Documento b explica el razonamiento criterio a criterio para las métricas de mayor impacto.

P: ¿Cómo se resuelve el problema del Independiente (I = 3.5)?

R: Mediante controles compensatorios: auditorías independientes periódicas (Auditoría Interna o tercero), pruebas de penetración no anunciadas para validar MTDD/MTTR, y verificación externa de la completitud del inventario de activos e identidades.

P: ¿Está validado académicamente?

R: Las puntuaciones PRAGMATIC del presente catálogo son razonadas, no validadas empíricamente. La validación formal requeriría un estudio Delphi con expertos independientes y pruebas de campo. Este kit es el punto de partida para esa investigación.

Licencia y Citación

Licencia: Creative Commons Attribution-NonCommercial-ShareAlike 4.0 (CC BY-NC-SA 4.0)

Citación recomendada:

[Autores/Institución] (2026). *Kit GQM-PRAGMATIC v2025.1: Marco Integrativo de Trazabilidad y Calidad para Métricas de Ciberseguridad en el Marco COSO*. [Institución / DOI si disponible].

Créditos y Fuentes Primarias

- Basili, V.R. & Weiss, D.M. (1984). A Methodology for Collecting Valid Software Engineering Data. IEEE TSE.
- Basili, V.R., Caldiera, G. & Rombach, H.D. (1994). The Goal Question Metric Approach. Encyclopedia of SE.
- Brothby, K. & Hinson, G. (2013). PRAGMATIC Security Metrics. CRC Press / Auerbach.
- NIST SP 800-55 Rev. 2 (2022). Measurement Guide for Information Security. NIST.
- ISO/IEC 27004:2016. Information security management — Monitoring, measurement, analysis and evaluation. ISO.
- ISO/IEC 15939:2007. Systems and software engineering — Measurement process. ISO.
- COSO (2017). Enterprise Risk Management — Integrating with Strategy and Performance.
- COSO / PwC (2026). Corporate Governance: Guiding Principles for Board Oversight of Cybersecurity.
- ENISA (2025). NIS Investments 2025 — Cybersecurity Investment Trends in the EU.
- IBM Security (2025). Cost of a Data Breach Report 2025.
- FAIR Institute (2025). State of Cyber Risk Quantification Report 2025.
- CCN-CERT (2025). Ciberamenazas y Tendencias — Edición 2025.
- INCIBE (2026). Balance de Ciberseguridad 2025.
- NIST (2024). Post-Quantum Cryptography Standards (FIPS 203/204/205).

Versión: 2025.1 | Fecha: Abril 2026 | Clasificación: Libre (CC)
"No todo lo que se puede medir merece medirse.
No todo lo que merece medirse puede medirse fácilmente.
GQM+PRAGMATIC vive exactamente en esa tensión."